

Auditor evidence coverage matrix

v0 — 2026-07-14. Honest coverage report against a real-world request sequence for AI-assisted credit decisions.

Source of the sequence: practitioner input, 2026-07-14 — two working banking-audit professionals (one internal-audit consultant, one M&T Bank audit consultant) gave a 15-item priority order for how auditors and examiners actually consume evidence in a credit-decision review, plus a proposed evidence-bundle structure. This document is Shadow's honest coverage report against that request sequence. The item list below is a paraphrase; the original document remains private practitioner correspondence. Nothing in this matrix reproduces any specific regulator's or institution's internal checklist.

Purpose: be honest about what Shadow's evidence bundle covers today, what it partially covers, and what it does not cover at all.

Not covered is not a failure — it is a scope statement. Shadow is the cryptographic-attestation layer of an audit-ready evidence chain, not a full GRC platform. This matrix is what a working auditor should expect to receive if they hand a Shadow bundle to their team.

Companion docs: [STANDARDS_MAP.md](#) (EU AI Act Article 12 + OTel + ISO 24970 + prEN 18229-1) · [CITATION_MAP.md](#) (credit-decision regulatory citation chain) · [spec/EVIDENCE_BUNDLE.md](#).

Legend

-  **SHIPPED** — Shadow v2.0.3 emits this field, and the offline verifier can prove it wasn't altered.
-  **PARTIAL** — Shadow has the primitive but the operator must supply the content, or the field is present but not tied to the cryptographic chain.
-  **NOT COVERED** — Shadow does not produce this artifact. The operator must produce it from another system.
- **Honest expectation:** the top of the list (items 1–7) is where Shadow is thinnest, because those artifacts live in GRC / credit / compliance systems that predate any AI-attestation layer. Shadow's strongest coverage is 12–14. **This is the reverse of the order auditors actually consume evidence in.** That gap is the roadmap.

Governance-tier request sequence

The order below reflects how a real audit or examination typically walks through a credit-decision review: business context first, human accountability second, technical integrity last.

#	Requested artifact	Shadow coverage	Bundle field / module	Gap notes
1	Executive summary of the decision	 NOT COVERED	—	Belongs in the operator's credit memo system. Shadow can <i>carry</i> an operator-produced summary in <code>header.custom</code> but does not generate it. Roadmap: a summary-slot in <code>bundle_index.json</code> (see §Roadmap).
2	Credit memorandum / underwriting package	 NOT COVERED	—	Operator's LOS (loan origination system) output. Shadow does not know underwriting facts unless the operator emits them as <code>tool_result</code> or <code>file_write</code> events.
3	Human approval	 PARTIAL	<code>events[event_type=human_approval].payload_hash</code> + <code>.actor</code>	The event type exists and hash-chain-binds an approval payload.

#	Requested artifact	Shadow coverage	Bundle field / module	Gap notes
	record			What is missing today: structured approver identity (<code>approver_id</code> , <code>role</code> , <code>approval_timestamp</code> , <code>approval_comments</code>) as first-class fields. Currently the operator must serialize these into the opaque payload. Roadmap: promote to structured extension in v3.0.
4	Adverse-action documentation (if applicable)	 PARTIAL	<code>events[event_type=tool_call].extensions</code> when the operator invokes an AA-code generator	Shadow records the AA-code decision as a tool call and chain-binds it. It does not itself validate AA-code contents against Reg B §1002.9. Reg B compliance remains the operator's obligation. See CITATION MAP.md for the citation chain.
5	Applicable policy or procedure	 NOT COVERED	—	Operator's policy management system. Shadow can carry a policy hash reference in <code>header.custom.policy_refs[]</code> but does not host policy text.
6	Decision rationale + supporting evidence	 PARTIAL	<code>events[event_type=model_output].payload_hash</code> + <code>events[event_type=tool_result].payload_hash</code>	The model's reasoning trace and the evidence it consulted are captured verbatim and hash-chained. Gap: no structured "rationale summary" field. An auditor reading the bundle sees the raw trace, not a curated rationale paragraph.
7	AI governance documentation	 NOT COVERED	—	Operator's model-risk governance library. Shadow's <code>header.models[]</code> names the models but does not carry governance metadata (policy version, approval date, risk tier). Roadmap: <code>header.governance_refs[]</code> slot in v3.0.
8	Model inventory entry	 PARTIAL	<code>header.models[]</code>	Manifest names each model used in the session (provider + model_id + version). Gap: no owner, no intended-use statement, no risk tier.
9	Validation report	 NOT COVERED	—	Model validation is upstream of the runtime session. Shadow can carry a report hash but not the report.
10	Test evidence	 SHIPPED	Repo-level: <code>test/</code> (1,504 passing tests · Node.js <code>node:test</code> · Python cross-language verifier · GitHub Actions matrix on macOS/Ubuntu/Windows)	The repo's own test evidence is public and re-runnable. What is

#	Requested artifact	Shadow coverage	Bundle field / module	Gap notes
				NOT in-bundle: per-decision test attribution.
11	Change-management records	✗ NOT COVERED	—	Operator's change-management system (ServiceNow, Jira, etc.). Shadow can reference a change ticket ID via <code>header.custom</code> but does not host tickets.
12	Audit logs (reconstruct the decision timeline)	✓ SHIPPED	Whole bundle. <code>events[]</code> in strict monotonic sequence, hash-chained, tamper-evident. <code>batch_root</code> seals the entire chain.	This is the item Shadow is purpose-built for. An auditor with a Shadow bundle can reconstruct the timeline offline, byte-for-byte, without trusting the operator.
13	Security evidence (integrity, access, encryption)	✓ SHIPPED	<code>signatures[]</code> (Ed25519 per RFC 8032) · <code>external_anchors[]</code> (RFC 3161 TSA + Sigstore Rekor when the operator wires them per M3) · <code>batch_root</code> (Merkle root of event hashes)	Signature integrity is independently verifiable via the offline HTML verifier, the CLI (<code>npx shadow-verify</code>), or the GitHub Action.
14	Operational monitoring (post-deployment)	● PARTIAL	<code>events[event_type=error]</code> + operator-emitted monitoring events	Shadow records what the agent emits at runtime. It does not itself poll production for drift or performance regression — that is the operator's monitoring stack.
15	Governance-committee approvals	✗ NOT COVERED	—	Board / committee minutes live in the operator's governance system. Shadow can reference an approval ID in <code>header.custom</code> but does not host minutes.

Supporting technical evidence

Auditors also request supporting technical artifacts. Shadow's coverage here is stronger because these live closer to the runtime session:

Category	Item	Shadow coverage	Notes
Software governance	Source-code repo reference	✓ SHIPPED	<code>header.agent.identity_ref</code> binds session to a specific source (git-URL-like).
Software governance	Release version	✓ SHIPPED	<code>header.agent.agent_version</code> + <code>header.attest_core_version</code> .
Software governance	Git commit identifier	● PARTIAL	Currently carried via <code>header.custom</code> if the adapter emits it. Roadmap: promote to first-class <code>header.agent.git_sha</code> in v3.0.
Software governance	Build identifier	✗ NOT COVERED	Operator's CI system.
Software governance	CI/CD execution	✗ NOT COVERED	Operator's CI system. Shadow can reference a run ID.

Category	Item	Shadow coverage	Notes
	logs		
Software governance	Deployment approval	✗ NOT COVERED	Operator's change-management system.
Testing evidence	Unit / integration / regression / security / performance tests	✓ SHIPPED (repo-level)	1,504 tests across the packages. NOT tied to individual sessions.
Testing evidence	Coverage summary	● PARTIAL	Available in CI artifacts, not embedded per-session.
Model governance	Model inventory / owner / intended use / limitations	✗ NOT COVERED	See governance-tier item 8.
Operational evidence	User initiating workflow	✓ SHIPPED	<code>header.agent.identity_ref</code> (agent side) + <code>events[event_type=user_message].actor</code> (user side).
Operational evidence	Timestamp	✓ SHIPPED	Every event: <code>ts_utc</code> .
Operational evidence	Data sources used	● PARTIAL	<code>events[event_type=tool_call]</code> names the tool; the tool's own source references are opaque unless the tool emits them.
Operational evidence	Inputs / outputs	✓ SHIPPED	<code>events[event_type=model_call/tool_call/model_output/tool_result].payload_hash</code> — content is content-addressed and separable from the chain (see §Content-addressing note below).
Operational evidence	Human reviewer / final disposition / exceptions / escalations	● PARTIAL	See governance-tier item 3.
Security evidence	Auth / authz logs, encryption status, access history, admin actions	✗ NOT COVERED	Operator's IAM / SIEM. Shadow can reference session IDs.

Content-addressing note

Shadow separates event *content* from event *hash*. The bundle carries `payload_hash` (32-byte SHA-256) on-chain; the raw payload is stored side-car and can be evicted for GDPR erasure requests **without breaking the chain**. Chain integrity is preserved because the hash is what is signed; deletion of the content becomes an explicit, detectable event in itself. This is important for auditors reviewing decisions under GDPR Art. 17 alongside record-keeping obligations.

The 4 lines an auditor will actually verify

An auditor handed a Shadow bundle can, in five minutes, independently establish:

1. **Chain integrity.** Every `event[i].prev_hash` equals `sha256(event[i-1])`. If any byte in any event was altered post-emission, the chain breaks at that seq number and every downstream event is marked **✗**.
2. **Signature validity.** The `batch_root` was signed by a key whose fingerprint matches the operator's published `/api/attestation-info` endpoint (or their pinned public key). Ed25519 per RFC 8032.
3. **External anchor (when present).** If `external_anchors[]` contains an RFC 3161 timestamp, the auditor can verify the TSA's signature independently, proving the bundle existed no later than time T. If a Sigstore Rekord entry is present, the auditor can query the public transparency log directly.
4. **Cross-language consistency.** The Node.js verifier (`packages/attest-core`) and the Python verifier (`packages/attest-verify-python`) produce byte-identical verification reports on the same bundle, computed by independent implementations of the canonical payload rules. This is the "verify without trusting us" property.

None of these four verifications require the operator's cooperation.

Roadmap: closing the gaps 1–11

The strongest single upgrade Shadow can make in the next 18 days (before 8/2 launch) is to **reorganize the bundle presentation** to match the auditor's consumption order, without over-scoping into GRC territory:

- **`bundle_index.json` (v0.1 target: 2026-07-25).** A small side-car file that names each carried field by the practitioner category (executive summary, decision context, human decision, AI analysis, policy mapping, technical integrity, traceability), so a reviewer opens the bundle and sees governance-shape first, not raw JSON. This is a naming layer over existing fields, not a schema change.
- **`REPORT.md` (v0.1 target: 2026-07-25).** A human-readable summary auto-rendered from the bundle in the same order, so an auditor gets one PDF-printable page before drilling into JSON. Uncovered categories are **explicitly labeled NOT COVERED** with a pointer to the operator system that should supply them.
- **Structured `human_approval` extension (v3.0).** Promote `approver_id` / `role` / `approval_timestamp` / `approval_comments` to first-class fields so the audit chain does not have to unwrap the opaque payload for the third-most-requested item on the auditor's list.
- **Structured `header.governance_refs[]` + `header.agent.git_sha` (v3.0).** First-class references (not free-form `custom`) so the bundle carries stable pointers to the operator's governance library and source tree.

Deliberately NOT roadmapped: 13 PDF generators (executive summary PDF, decision context PDF, deployment record PDF, etc.), a `Traceability_Matrix.xlsx` generator, a policy management system, a model inventory system, or a change-management system. Those are GRC-platform features. Shadow's north star is the cryptographic-attestation layer; the roadmap above adds *presentation* of that layer in auditor-native shape, not the substitution of GRC systems Shadow does not build.

The one sentence for the paper

Shadow organizes the fields it does carry in the same order that audit, model-risk, and compliance reviewers typically consume evidence — beginning with business context and human accountability, then progressing through policy mapping,

model governance, testing, technical verification, and cryptographic integrity. Uncovered categories are explicitly labeled so that no auditor mistakes a Shadow bundle for a complete GRC record; the bundle is honest about the boundary of what a cryptographic–attestation layer can and cannot substitute for.

(This framing is grounded in established governance practice as reported by working practitioners; it does not claim to reproduce any specific regulator's or institution's internal review checklist.)